

Informe de análisis y mejora de la seguridad física

Carrera:Ingeniería en ciberseguridad
Asignatura:Gobernanza

Profesor: Andrea Fernández
Fecha de envío: 12/07/2025
Nombre(s) de estudiante(s):Javier Cerda Salas

Índice

1.Introducción.

2.Análisis de riesgos Basado en ISO 31000.

2.1Contextualización de la organización.

2.2 Clasificación de los Activos de la Organización

2.3 Vulnerabilidades halladas.

2.4 Análisis del riesgo encontrado

2.5 Evaluación de los riesgos

2.6 Propuestas de Mejora

2.7 Tratamiento de Riesgos

3.0 Plan de Implementación

4.0 Conclusión



1.Introducción

Para este informe fue elegido el caso n°1 ,en los siguientes párrafos se hará una contextualización de dicho caso.

Este caso se contextualiza en una consultoría realizada a la empresa Cliente , dicha empresa presenta el traslado de sus instalaciones a otro espacio físico basada por lo cual en las siguientes páginas , se realiza un análisis integral donde se buscará cumplir con los siguientes objetivos:

- Realizar un análisis de la organización y contextualizarla en el tiempo.
- Realizar un análisis de riesgo basado en la organización aplicando principios de la norma ISO 27001 y 31000.
- Realizar búsqueda de vulnerabilidades y realizar sugerencia de mejoras para suplir dichas vulnerabilidades.



2. Analisis de riesgos Basado en ISO 31000

2.1 Contextualización de la organización

La Empresa Cliente arrendó un área dentro de un edificio de cowork moderno que les ofrece flexibilidad para personalizar sus instalaciones. Actualmente, el área destinada a la operación principal se encuentra en proceso de remodelación para transformarse en una zona exclusiva con acceso restringido.

El cowork proporciona un control de acceso central basado en un recepcionista y un guardia que puede habilitar el ingreso mediante una tarjeta maestra en caso de que un colaborador olvide su credencial. Sin embargo, los colaboradores no poseen tarjetas identificadoras y el sistema sólo verifica identidad la primera vez que ingresan. Luego, las personas pueden desplazarse libremente dentro de las diferentes instalaciones de la empresa.

Contexto general : Evaluar los riesgos asociados de las nuevas dependencias asociados al control de acceso físico de la zona exclusiva de la Empresa Cliente en el edificio cowork LATAM, actualmente en proceso de remodelación.

Objetivos:

- Garantizar la confidencialidad, integridad y disponibilidad de la información y activos físicos de la empresa.
- Minimizar el riesgo de accesos no autorizados a áreas críticas.
- Proteger la seguridad del personal y la continuidad operativa.

2.2 Clasificación de los Activos de la Organización:

La organización cuenta con los siguientes activos:

- Información confidencial que corresponde a :datos de clientes, información confidencial de la organización .
- Moviliario: Equipos electrónicos y servidores alojados en la zona exclusiva.

2.2. Riesgos encontrados:

Se identificaron los siguientes riesgos relevantes asociados al entorno físico y organizacional:

- Ingreso no autorizado a la zona exclusiva: Esto ocurre porque se generan accesos no controlados desde zonas comunes como se puede ver en la imagen 1 .Donde se presenta una zona exclusiva sin accesos controlados.

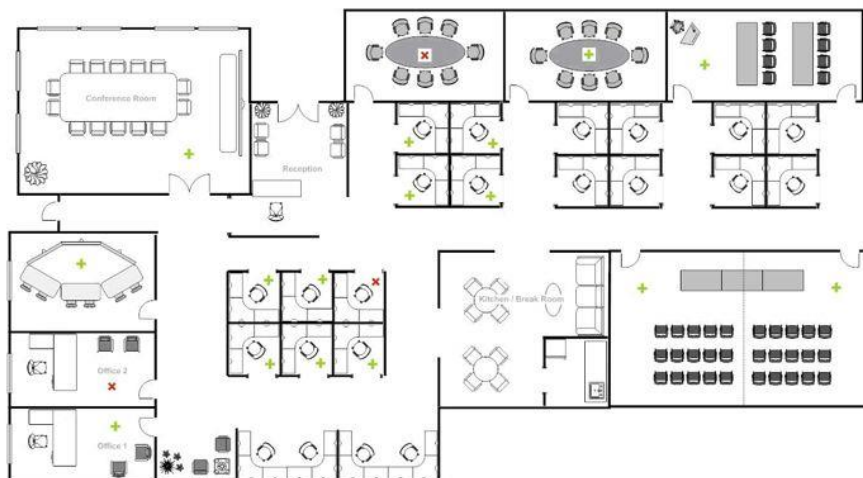


Imagen 1 : Mapa de distribución de planta física

- **Suplantación de identidad:** Este riesgo se presenta debido a que la organización no posee credenciales obligatorias para cada colaborador o visita.
- **Exposición de información confidencial:** Esto puede generarse derivado de un acceso no controlado y suplantación de identidad , provocando la intrusión por parte de personal externo o también filtración de datos por parte de personal interno de la organización.
- **Robo o daño a activos físicos:** Servidores, notebooks , entre otros activos que posea la organización.
- **Intrusión social (tailgating):** Al no poseer un control exhaustivo de personal externo o interno que este autorizado para acceder a la zona exclusiva puede aprovecharse de reuniones para acceder al sitio y acceder a información confidencial.
- **Falta de trazabilidad :** Producido por ausencia de registros automáticos de entradas y salidas desde la zona exclusiva, solo poseemos un torniquete en el acceso principal donde se registra el ingreso por primera vez, pero , no existe trazabilidad de quien ingreso o salió de la zona exclusiva en un horario predeterminado.

2.3 Vulnerabilidades halladas:

En el análisis de la consultoría se encontraron las siguientes vulnerabilidades:

- **Ausencia de controles de acceso:** Cuenta con un solo control de acceso el cual está en el acceso principal, pero no delimita la zona exclusiva .
- **Torniquetes sin efectividad:** Presenta torniquetes , pero ningun colaborador posee una tarjeta de identificación que posea medidas de verificación como (banda magnetica, chips) entre otros.No existe verificadores biometricos mediante huella digital que permita un trazado continuo del acceso y salida de personal.
- **Ausencia de barreras fisicas:** No existen muros definidos, puertas de alta seguridad y Falta de cámaras que cubran pasillos y accesos alternativos.
- **Ausencia de medidas de vigilancia:** No existe presencia de camaras de seguridad con grabación de video, reconocimiento facial y grabado de audio.

2.4 Analisis del riesgo encontrado

Se realizo un mapa de calor basado en la estratificación de los riesgos encontrados y en base a la probabilidad de ocurrencia e impacto provocado. Para ello, se definieron niveles cualitativos para evaluar la probabilidad de ocurrencia (Baja, Media, Alta) e impacto con una escala (Bajo, Medio, Alto,Critico).

Se definió la siguiente tabla de probabilidad:

Criterio de probabilidad	Definición
Baja	La amenaza puede materializarse a lo mas una vez al año
Media	La amenaza puede consumarse de dos a cuatro veces al año
Alta	La amenaza se materializa al menos una vez al mes

Mientras que por otro lado se definió la siguiente tabla de impacto:

Criterio de impacto	Definición
Moderado	El daño provocado no interfiere en la operación de la organización
Medio	El daño provocado podría interferir en la operación si se materializa

Alta	El daño provocado detiene las operaciones esenciales y expone información de la organización
------	--

Riesgo identificado	Probabilidad	Impacto	Nivel de riesgo
Ingreso no autorizado	Alta	Alto	Crítico
Suplantación de identidad	Media	Alto	Alto
Robo de equipos	Baja	Alto	Alto
Intrusión (Tailgating)	Media	Medio	Alto
Falta de registros de entrada y salida	Media	Medio	Alto

Mapa de calor

2.5 Evaluación de los riesgos

Los riesgos fueron evaluados basados en los criterios previos y se generó un mapa de calor. De lo cual, se extrae que para ser tratados todos los riesgos identificados que generen un nivel de riesgo que sean categorizados en las categorías de alto o crítico. Por ende, los riesgos a tratar serían los siguientes: Ingreso no autorizado, suplantación de identidad, robo de equipos, intrusión, falta de registros de entrada y salida.

Para realizar esta propuesta, se analizó tanto los riesgos como también posible implementación de controles

2.6 Propuestas de Mejora

Para realizar esta propuesta, se analizó tanto los riesgos como también posible implementación de controles basados en la norma ISO 27002 y la evaluación de los riesgos mostrados en el mapa de calor.

Para ello, se generó una tabla basada en los riesgos identificados, controles aplicables de la norma ISO 27002:2022 y la justificación de la posible elección



Riesgo identificado	Control aplicable	Justificación de la aplicabilidad
Ingreso no autorizado	7.4 Monitorización de la seguridad física. 7.5 Protección contra las amenazas externas y ambientales	Limita el acceso a áreas específicas solo a personal autorizado. Permite la implementación de barreras físicas y mecanismos para impedir el acceso no autorizado.
Suplantación de identidad	5.16 Gestión de identidad	Asegura que solo usuarios autenticados con mecanismos seguros puedan acceder.
Robo de activos físicos	7.3 Seguridad de oficinas , despachos y recursos. 8.9 Gestión de la configuración	Permite la protección de las instalaciones y activos físicos frente a daños o robos mediante controles físicos y ambientales. Permite la implementación de mecanismos de seguridad a hardware y software.
Tailgating	6.3 Concienciación, educación y formación en seguridad de la información. 7.3 Seguridad de oficinas , despachos y recursos.	Permite educar al personal para evitar prácticas como abrir puertas a terceros no identificados. Permite la protección de las instalaciones y activos físicos frente a daños o robos
Falta de registros de accesos	5.15 Control de acceso. 7.5 Protección contra las amenazas externas y ambientales	Permite establecer mecanismos lógicos, tecnológicos y físicos de control en el acceso a las instalaciones

2.7 Tratamiento de Riesgos

La siguiente tabla de autoría propia, esta confeccionada basándose en una asociación de conceptos que considera las siguientes asociación de variables : los riesgos que se identificaron, los controles de la norma ISO 27002 aplicables , la estrategia de tratamiento del riesgo y los responsables sugeridos de la organización para su implementación.

Riesgo Identificado	Controles Aplicables ISO 27002	Estrategia de tratamiento	Acciones recomendadas	Responsable sugerido
Ingreso no autorizado	7.4 Monitorización de la seguridad física 7.5 Protección contra amenazas externas y ambientales	Mitigar	- Instalar CCTV en accesos y zonas críticas. - Implementar puertas automáticas con cerraduras electrónicas y autenticación (huella, QR). - Establecer muros y torniquetes que delimiten áreas restringidas.	Gerencia de seguridad / equipo de Infraestructura
Suplantación de identidad	5.16 Gestión de identidad	Mitigar	- Implementar sistema de gestión de identidades (IAM). - Emitir credenciales únicas y obligatorias para colaboradores. - Integrar acceso físico y lógico bajo autenticación fuerte.	Área de TI / RRHH
Robo de activos físicos	7.3 Seguridad de oficinas,	Mitigar	- Clasificar activos críticos	Área de TI / Logística

	despachos y recursos 8.9 Gestión de la configuración		y asignar responsables. - Asegurar físicamente los dispositivos (anclajes, cajas de seguridad). - Documentar configuración y ubicación de hardware y software.	
Tailgating	6.3 Concienciación y formación en seguridad 7.3 Seguridad de oficinas, despachos y recursos	Mitigar	- Realizar campañas de concientización sobre tailgating. - Implementar sistemas de control de acceso individual (no duplicables). - Sensibilizar sobre la no apertura de puertas a terceros sin credencial.	Oficial de seguridad / RRHH
Falta de registros de accesos	5.15 Control de acceso 7.5 Protección contra amenazas externas y ambientales	Mitigar	- Establecer sistema de registro automático de ingresos y salidas (lector de QR / biometría). - Registrar accesos temporales y visitas. - Auditar	Seguridad física / TI

			periódicamente los logs de acceso físico.	
--	--	--	---	--

3.0 Plan de Implementación

En base a lo expuesto anteriormente se realizó un plan modelo de implementación basado en plazos en semanas para la implementación de las medidas.

Fase	Actividad principal	Duración estimada	Responsable
1	Evaluación y adquisición de equipos de seguridad	4 semanas	TI / Seguridad
2	Construcción de muros y puertas de alta seguridad	4 semanas	Infraestructura
3	Despliegue de credenciales e IAM	2 semanas	TI / RRHH
4	Instalación de CCTV y sensores	3 semanas	Seguridad Electrónica
5	Capacitación y pruebas piloto	2 semanas	Oficial de Seguridad
6	Arranque y monitoreo continuo	Permanente	Gerencia de Seguridad

4.0 Conclusiones

El presente análisis confirma que la seguridad física actual no satisface los requisitos básicos del Sistema de Gestión de Seguridad de la Información (SGSI) basado en ISO 27001. La materialización de uno solo de los riesgos identificados podría comprometer aspectos tales como la confidencialidad de los datos, la integridad de los activos y la disponibilidad de las operaciones de la organizaciones por ello, que la implementación de las acciones recomendadas ofrecen un enfoque estructurado, gradual y viable para alcanzar un nivel de riesgo residual aceptable y permitir que el cambio de planta física sea optimo para la organización tanto en sentidos de espacio físico, como también asegurar la seguridad de la información de la empresa.



5. Referencias Bibliográficas

- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (3.ª ed.). ISO..
- International Organization for Standardization. (2018). *ISO 31000:2018 Risk management – Guidelines* [Standard]. ISO
- International Organization for Standardization. (2022). *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection – Information security controls* [Standard]. ISO / IEC.
- Informe de consultoría de seguridad perimetral, Empresa Cliente, Septiembre 2024.